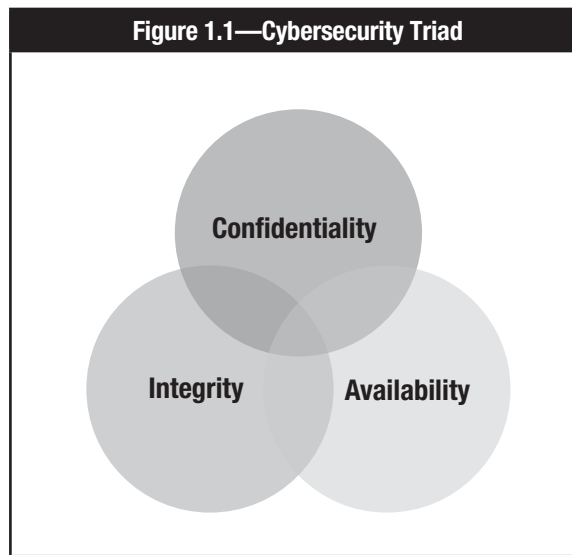


TOPIC 1—INTRODUCTION TO CYBERSECURITY

THE EVOLUTION OF CYBERSECURITY

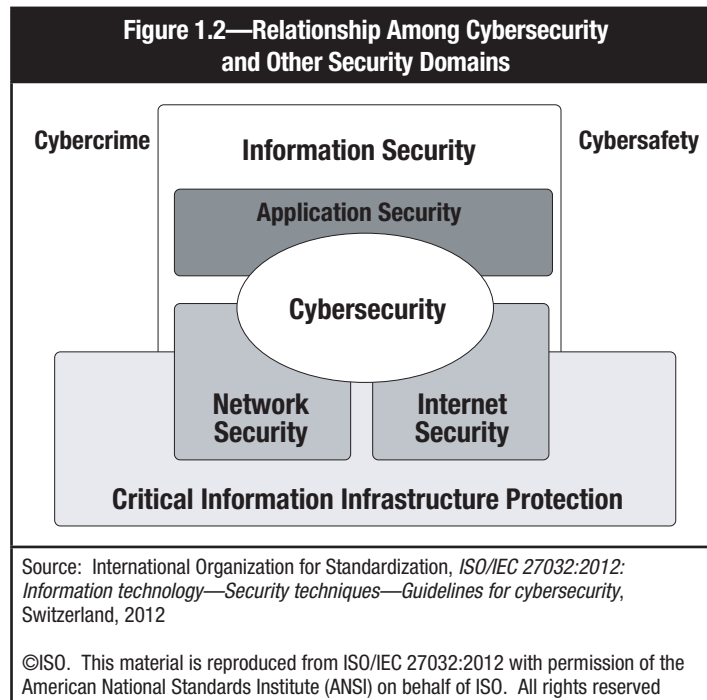
Safeguarding information has been a priority for as long as people have needed to keep information secure and private. Even simple encryption techniques such as Caesar ciphers were created to ensure confidentiality. But as time and technology move forward, so do the demands of security. Today, the objective of information security is threefold, involving the critical components of confidentiality, integrity and availability (see **figure 1.1.**). All three components are concerned with the protection of information. **Confidentiality** means protection from unauthorized access, while **integrity** means protection from unauthorized modification, and **availability** means protection from disruptions in access.



The terms “cybersecurity” and “information security” are often used interchangeably, but in reality, cybersecurity is a part of information security. More specifically, **cybersecurity** can be defined as the protection of information assets by addressing threats to information processed, stored and transported by internetworked information systems.

Cybersecurity usually relates to an entity initiating threats due to the existence of a global cyberspace (i.e., Internet). Unlike information security, cybersecurity does not include natural hazards, personal mistakes or physical security. To put it even simpler, if we remove offensive and adversary human behavior threats coming through interconnected systems, cybersecurity would not be an issue, and information security alone would be sufficient.

Figure 1.2 shows the complex relationship among cybersecurity and other security domains, as described in International Organization for Standardization (ISO) 27032. For example, not all critical infrastructure services (e.g., water, transportation) will directly or significantly impact the state of cybersecurity within an organization. However, a lack of proper cybersecurity measures can negatively impact the availability and reliability of the critical infrastructure systems that are used by the providers of these services (e.g., telecommunications).¹



Managing cybersecurity issues requires coordination between many entities—public and private, local and globally—as cybersecurity is closely tied to the security of the Internet, enterprise and home networks, and information security. This can be complicated because, due to matters of national security, some critical infrastructure services are not openly discussed and knowledge of weaknesses to these services can have a direct impact on security. Therefore, a basic framework for information sharing and incident coordination is needed to provide assurance to stakeholders that cybersecurity issues are being addressed.²

CYBERSECURITY AND SITUATIONAL AWARENESS

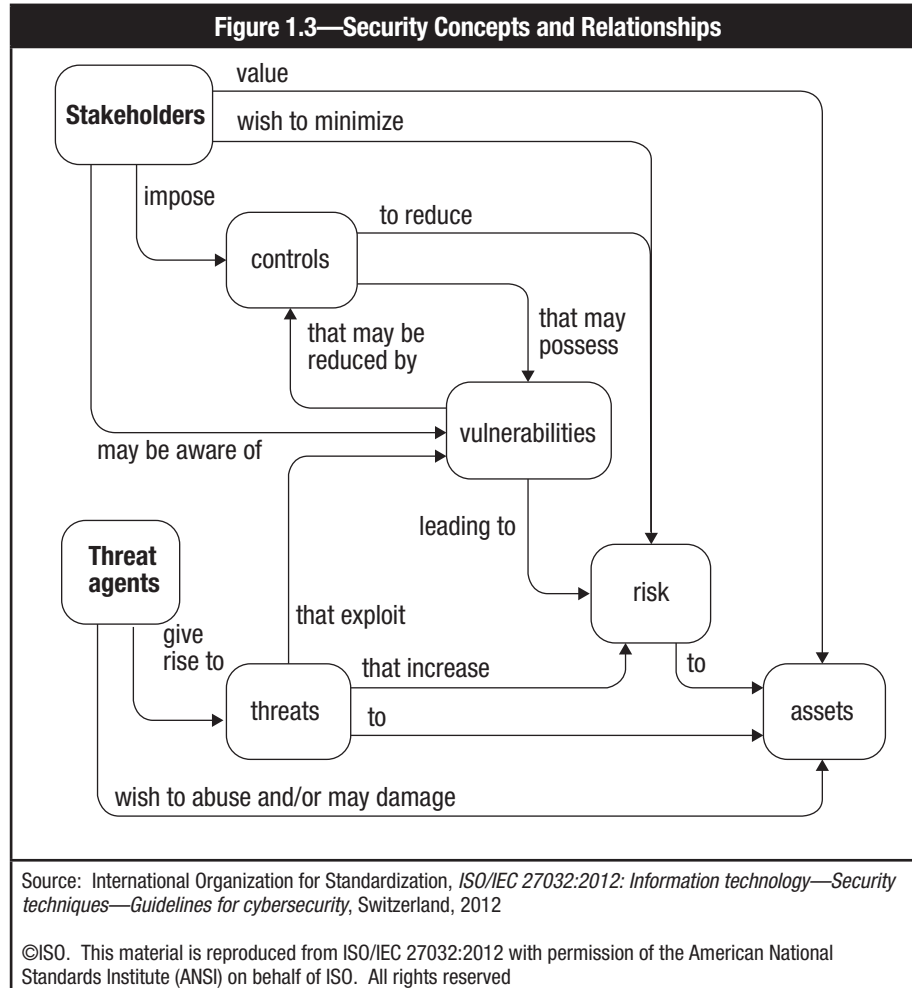
Cybersecurity plays a significant role in the ever-evolving cyber landscape. New trends in mobility and connectivity present a broad range of challenges as new attacks continue to develop along with emerging technologies. Cybersecurity professionals must be informed and flexible to identify and manage potential new threats, such as new cybercrime methods and advanced persistent threats (APTs), effectively. APTs are attacks by an adversary who possesses sophisticated levels of expertise and has the time, patience and significant resources, which allow the attacker to create opportunities to achieve its objectives using multiple attack vectors.

To successfully protect their systems and information, cybersecurity professionals must demonstrate a high degree of situational awareness. This takes time to cultivate, because it usually develops through experience within a specific organization. Each organization has its own distinct culture, which means that conditions vary widely from one organization to another. Therefore, it is critical for cybersecurity professionals to have a detailed understanding of the environment in which they operate and a broader ongoing awareness of threats affecting other organizations and industries to ensure relevant knowledge is maintained.

¹ International Organization for Standardization, *ISO/IEC 27032:2012: Information technology—Security techniques—Guidelines for cybersecurity*, Switzerland, 2012

² *Ibid.*

The protection of assets from threats is a primary concern for security in general. Threats, in turn, are then categorized related to the likelihood (i.e., potential) that they will impact protected assets. In security, threats that are related to malicious or other human activities are often given greater attention. **Figure 1.3** gives an illustration of these security concepts and relationships.



The responsibility for protecting these assets lies with the stakeholders to whom these assets have value. Therefore, stakeholders should take threats into consideration when assessing risk to these assets. This risk assessment, discussed in section 4.1, will help in the process of control selection. Controls used to protect assets, reduce vulnerabilities and impacts, and/or reduce risk to an acceptable level. They should be monitored and reviewed to ensure that each specific control is adequate to counter the risk it is designed to mitigate. It is important to keep in mind that risk cannot be eliminated, resulting in residual risk. Stakeholders should aim to minimize the level of residual risk. It may also be necessary to use external resources to ensure that controls are functioning properly.

The business environment, in particular, tends to drive risk decisions. For example, a small start-up company may be much more tolerant of risk than a large, well-established corporation. Therefore, it can be helpful to reference broad criteria listed below when evaluating the drivers affecting the security of a specific organization.

With respect to technology, many factors can impact security, such as:

- Level of IT complexity
- Network connectivity (e.g., internal, third-party, public)
- Specialist industry devices/instrumentation
- Platforms, applications and tools used
- On-premise cloud or hybrid systems
- Operational support for security
- User community and capabilities
- New or emerging security tools

When evaluating business plans and the general business environment, consider drivers, such as:

- Nature of business
- Risk tolerance
- Risk appetite
- Security mission, vision and strategy
- Industry alignment and security trends
- Industry-specific compliance requirements and regulations
- Regional regulatory and compliance requirements
 - Country or state of operation
- Mergers, acquisitions and partnerships
 - Consider type, frequency and resulting level of integration
- Outsourcing services or providers

Although business and technology drivers cannot all be predicted with certainty, they should be anticipated reasonably and handled as efficiently as possible. Failure to anticipate key security drivers reflects an inability to effectively react to changing business circumstances, which in turn results in diminished security and missed opportunities for improvement.

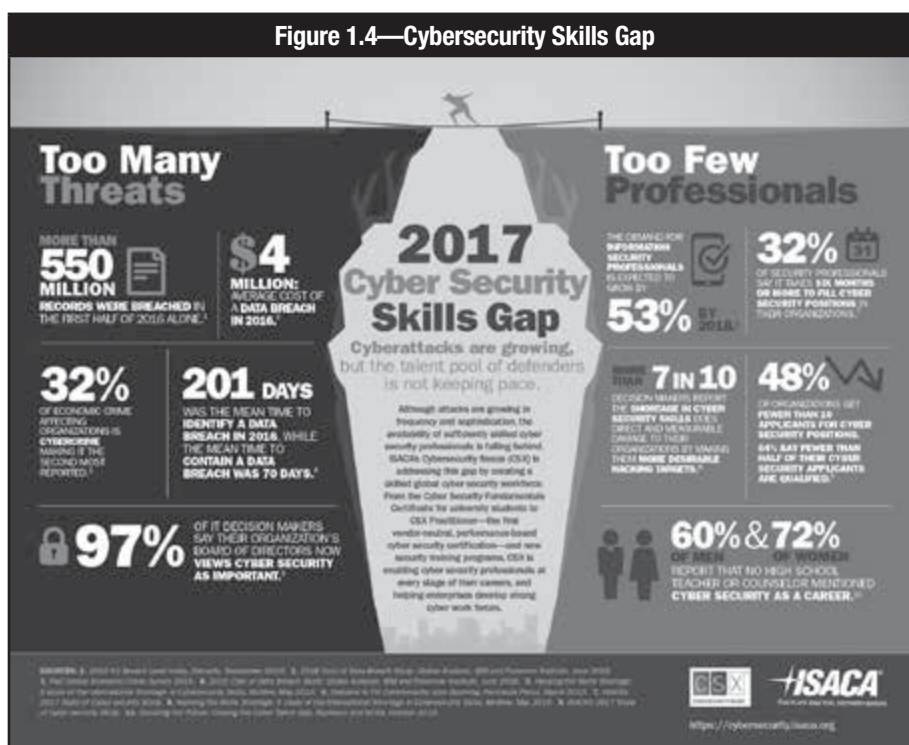
THE CYBERSECURITY SKILLS GAP

Cybersecurity is a field that demands skilled professionals who possess the foundational knowledge, education and thought leadership necessary to confront the difficulties that accompany constant technological change. Advanced threat vectors, emerging technologies and a myriad of regulations require cybersecurity professionals to be skilled in technology as well as business and communications.

Cybersecurity addresses both internal and external threats to an organization's digital information assets by focusing on critical electronic data processes, transaction processing, risk analytics and information system security engineering.

There are an estimated 410,000 to 510,000 information security professionals worldwide, and jobs are expected to increase 53 percent by 2018 with over 4.2 million jobs available. However, recent studies and reports suggest that there are simply not enough skilled professionals to fill them.

While the cybersecurity landscape has evolved, the skill set among existing and potential cybersecurity professionals has not kept pace. There is a shortage of skilled professionals in the cybersecurity profession, as seen in **figure 1.4**. According to the ISACA 2017 *State of Cybersecurity Study*, 48% of organizations get fewer than 10 applicants for cybersecurity positions, and 64% say fewer than half of their cybersecurity applicants are qualified.³ Likewise, the European Union's (EU's) digital agenda commissioner believes that the growing cybersecurity skills gap is threatening the EU's competitiveness. Skills gaps are seen in both technical and business aspects of security. This guide provides an overview of these business and technical practices, along with various other methodologies and procedures related to cybersecurity.



³ ISACA, 2017 *State of Cybersecurity Study*, <https://cybersecurity.isaca.org>

Page intentionally left blank

TOPIC 2—DIFFERENCE BETWEEN INFORMATION SECURITY AND CYBERSECURITY

Information security deals with information, regardless of its format—it encompasses paper documents, digital and intellectual property in people’s minds, and verbal or visual communications. **Cybersecurity**, on the other hand, is concerned with protecting digital assets—everything encompassed within network hardware, software and information that is processed, stored within isolated systems or transported by internetworked information environments. Additionally, concepts such as nation-state-sponsored attacks and APTs belong almost exclusively to cybersecurity. It is helpful to think of cybersecurity as a component of information security.

Therefore, to eliminate confusion, the term cybersecurity will be defined in this guide as the protection of information assets by addressing threats to information processed, stored and transported by internetworked information systems.

PROTECTING DIGITAL ASSETS

In the core of its cybersecurity framework, the National Institute of Standards and Technology (NIST) identifies five key functions necessary for the protection of digital assets. These functions coincide with incident management methodologies and include the following activities:⁴

- **Identify**—Use organizational understanding to minimize risk to systems, assets, data and capabilities.
- **Protect**—Design safeguards to limit the impact of potential events on critical services and infrastructure.
- **Detect**—Implement activities to identify the occurrence of a cybersecurity event.
- **Respond**—Take appropriate action after learning of a security event.
- **Recover**—Plan for resilience and the timely repair of compromised capabilities and services.

⁴ National Institute of Standards and Technology (NIST), *Framework for Improving Critical Infrastructure Cybersecurity*, USA, 2014, www.nist.gov/sites/default/files/documents/cyberframework/cybersecurity-framework-021214.pdf

Page intentionally left blank

TOPIC 3—CYBERSECURITY OBJECTIVES

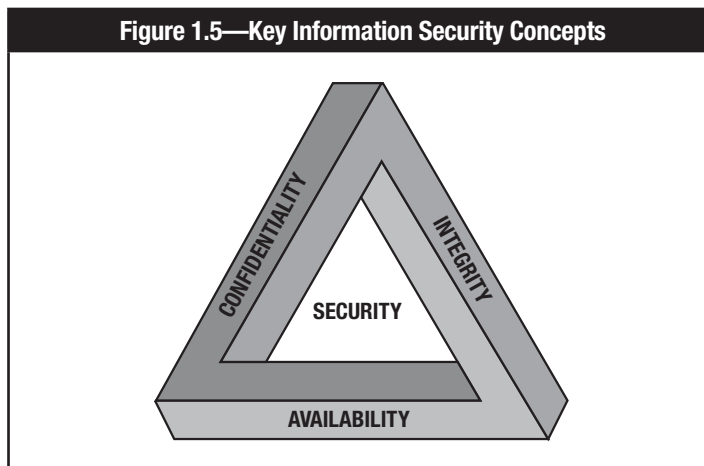
Cybersecurity requires stakeholders in the cyberspace area to be active in security, beyond the protection of their own assets. They should be prepared to identify and address emerging risk and challenges to keep assets protected. Cybersecurity works with information security and is beyond merely Internet, network and/or application security. It requires working with all of these components in order to keep the cyberspace useful and trustworthy.

Cybersecurity aims to meet certain objectives in the protection of digital assets. These include the confidentiality, integrity and availability of the assets among other aspects. These are discussed in detail in this topic.

CONFIDENTIALITY, INTEGRITY AND AVAILABILITY

To better understand cybersecurity and the protection of digital assets, it is helpful to consider three key concepts that are used to guide information security policies, as shown in **figure 1.5**. The concepts are:

- Confidentiality
- Integrity
- Availability



Confidentiality is the protection of information from unauthorized access or disclosure. Different types of information require different levels of confidentiality, and the need for confidentiality can change over time. Personal, financial and medical information require a higher degree of confidentiality than the minutes of a staff meeting, for example. Similarly, some companies need to protect information on competitive future products before their release but may need to make the same information public afterward.

Data must be protected from improper disclosure according to its sensitivity and applicable legal requirements. The confidentiality of digital information can be maintained using several different means, including access controls, file permissions and encryption.

Integrity is the protection of information from unauthorized modification. For example, if a bank transfers \$10,000 to another financial institution, it is important that the amount does not change to \$100,000 during the exchange. The concept of integrity also applies to electronic messaging, files, software and configurations.

Any violation of integrity is significant because it may be the first step in a successful attack against system availability or confidentiality. Contaminated systems and corrupted data must be dealt with immediately to assess the potential for further violation or damage. The integrity of digital assets can be controlled and verified by logging, digital signatures, hashes, encryption and access controls.

Availability ensures the timely and reliable access to and use of information and systems. This includes safeguards to make sure data are not accidentally or maliciously deleted. This is particularly important with a mission-critical system, because any interruptions in its availability can result in a loss of productivity and revenue. Similarly, the loss of data can impact management's ability to make effective decisions and responses. Availability can be protected by the use of redundancy, backups and implementation of business continuity management and planning (see Section 5, Topic 5 for more information).

The impacts, potential consequences and methods of control of confidentiality, integrity and availability are shown in **figure 1.6**.

Figure 1.6—Confidentiality, Integrity and Availability Model and Related Impacts		
Requirement	Impact and Potential Consequences	Methods of Control
Confidentiality: The protection of information from unauthorized disclosure	Loss of confidentiality can result in the following consequences: • Disclosure of information protected by privacy laws • Loss of public confidence • Loss of competitive advantage • Legal action against the enterprise • Interference with national security • Loss of compliance	Confidentiality can be preserved using the following methods: • Access controls • File permissions • Encryption
Integrity: The accuracy and completeness of information in accordance with business values and expectations	Loss of integrity can result in the following consequences: • Inaccuracy • Erroneous decisions • Fraud • Failure of hardware • Loss of compliance	Integrity can be preserved using the following methods: • Access controls • Logging • Digital signatures • Hashes • Backups • Encryption
Availability: The ability to access information and resources required by the business process	Loss of availability can result in the following consequences: • Loss of functionality and operational effectiveness • Loss of productive time • Fines from regulators or a lawsuit • Interference with enterprise's objectives • Loss of compliance	Availability can be preserved using the following methods: • Redundancy of network, system, data • Highly available system architectures • Data replication • Backups • Access controls • A well-designed disaster recovery plan or business continuity plan

NONREPUDIATION

Nonrepudiation is an important consideration in cybersecurity. It refers to the concept of ensuring that a message or other piece of information is genuine. When information is sent, it is important to verify that it is coming from the source that it says it is coming from. Nonrepudiation provides a means so that the person who sends or receives information cannot deny that they sent or received the information. It is implemented through digital signatures and transactional logs.